

Informe Ejecutivo de Seguridad

Vulnerable Accounting System

Resumen Ejecutivo

Se realizó una evaluación de seguridad completa sobre el sistema de contabilidad, identificando 45 vulnerabilidades que representan un riesgo crítico para la organización. El sistema presenta múltiples fallas que permiten a atacantes obtener control total del servidor y acceso a información financiera confidencial. **Hallazgos Críticos**

12 vulnerabilidades críticas fueron identificadas, incluyendo:

- Ejecución Remota de Código (RCE): 3 endpoints permiten ejecutar comandos del sistema
- SQL Injection: 3 endpoints vulnerables permiten acceso completo a la base de datos
- Bypass de Autenticación: Token hardcodeado permite acceso administrativo sin credenciales

Impacto del Negocio:

- Confidencialidad: Comprometida - Datos financieros accesibles sin autorización
- Integridad: Comprometida - Datos pueden ser modificados o eliminados
- Disponibilidad: En riesgo - Sistema puede ser comprometido completamente

Nivel de Madurez de Seguridad

Nivel Actual: 1/5 ⚠

Categoría	Nivel	Justificación
Gestión de Accesos	1/5	Sin autenticación en endpoints críticos, bypass de admin
Protección de Datos	1/5	Contraseñas en texto plano, SQL Injection masivo
Seguridad de Aplicación	1/5	Múltiples vulnerabilidades críticas (RCE, SQLi, XSS)
Gestión de Configuración	1/5	Debug activado, información expuesta, CORS permisivo
Monitoreo y Respuesta	0/5	Sin logging de seguridad, sin detección

de intrusiones Recomendación: Implementar mejoras inmediatas para alcanzar

nivel 3/5 en 6 meses.

Diagrama de Flujo de Ataque (Kill Chain)



```
Payload: SELECT * FROM users UNION SELECT ...
Endpoint: POST /api/debug/sql-execute
RESULTADO: Extracción de base de datos completa
```



```
FASE 5: EJECUCIÓN Y PERSISTENCIA
Vector 4: Command Injection
Payload: whoami; cat /etc/passwd
Endpoint: POST /api/debug/execute-command
RESULTADO: Control total del servidor (RCE)
```



```
IMPACTO FINAL
• Control total del servidor
• Acceso a todos los datos financieros
• Posibilidad de modificar/eliminar registros
• Compromiso de la infraestructura completa
```

Tiempo Estimado de Compromiso: < 30 minutos desde el reconocimiento inicial hasta el control total.

Recomendaciones Priorizadas

PRIORIDAD 1: Inmediata (0-7 días)

1. Deshabilitar endpoints de debug en producción
 - Eliminar `/api/debug/*` o proteger con autenticación fuerte
 - Impacto: Elimina 3 vulnerabilidades críticas de RCE
2. Implementar autenticación en todos los endpoints
 - Aplicar middleware de autenticación (Laravel Sanctum)
 - Eliminar token hardcoded de admin bypass Impacto: Previene acceso no autorizado
3. Migrar a consultas SQL preparadas
 - Reemplazar todas las consultas SQL directas por Eloquent ORM
 - Implementar validación estricta de entrada
 - Impacto: Elimina todas las vulnerabilidades de SQL Injection
4. Implementar hashing de contraseñas
 - Migrar contraseñas existentes a bcrypt/Argon2
 - Impacto: Protege credenciales en caso de filtración

PRIORIDAD 2: Corto Plazo (1-4 semanas)

5. Configurar CORS correctamente
 - Restringir orígenes permitidos
 - Impacto: Previene ataques desde dominios maliciosos
6. Ocultar información del servidor
 - Deshabilitar debug mode en producción
 - Remover headers informativos (X-Powered-By, Server) Impacto: Reduce superficie de ataque
7. Implementar CSRF protection
 - Agregar tokens CSRF a formularios
 - Impacto: Previene ataques de falsificación de solicitudes
8. Implementar rate limiting
 - Limitar intentos de login
 - Impacto: Previene fuerza bruta

PRIORIDAD 3: Mediano Plazo (1-3 meses)

9. Implementar Content Security Policy (CSP)

- o Prevenir XSS
- o Impacto: Reduce riesgo de robo de sesiones

10. Implementar logging y monitoreo

- o Registrar eventos de seguridad
- o Alertas de intrusiones
- o Impacto: Detección temprana de ataques

11. Auditoría de dependencias

- o Actualizar Laravel y componentes
- o Impacto: Elimina vulnerabilidades conocidas

Métricas de Riesgo

Métrica	Valor	Interpretación
Vulnerabilidades Críticas	12	Riesgo extremo
Tiempo de Compromiso	< 30 min	Muy rápido
Superficie de Ataque	20+ endpoints	Muy amplia
Probabilidad de Explotación	95%	Muy alta
Impacto en Negocio	Crítico	Pérdida total
Riesgo General: CRÍTICO		

Conclusión

El sistema presenta vulnerabilidades críticas que requieren acción inmediata. Se recomienda:

- 1.No desplegar en producción hasta remediar las vulnerabilidades críticas
- 2.Implementar las recomendaciones de Prioridad 1 antes de cualquier lanzamiento
- 3.Establecer un programa de seguridad continuo para mantener el nivel

de madurez Inversión Estimada: 40-80 horas de desarrollo para remediar vulnerabilidades críticas.